Cahier de laboratoires de l'étudiant CyberRiskGuardian

Douze laboratoires sur le cas pédagogique MediBec — Ensemble pédagogique 1.0

Marc-André Léger, Ph. D.

octobre 2026

Table des matières

Comment utiliser ce cahier 2

Laboratoire 0 — Prise en main 2

Laboratoire 1 — Contexte organisationnel et joyaux de la couronne 3

Laboratoire 2 — Appétence pour le risque 5

Laboratoire 3 — Rédaction de scénarios de risque 6

Laboratoire 4 — Quantification d'un scénario de risque 7

Laboratoire 5 — CVSS v4.0 pour un scénario de risque 9

Laboratoire 6 — Calcul et interprétation du risque 11

Laboratoire 7 — Traitement, contrôles partagés et risque résiduel 12

Laboratoire 8 — Sensibilité et incertitude 13

Laboratoire 9 — Indicateurs clés de risque 14

Laboratoire 10 — La note de service à la direction 15

Laboratoire 11 — Éléments probants des opérations de sécurité (facultatif, parcours application de bureau) 16

Laboratoire 12 — Du risque à la politique et à l'audit 17

Annexe A — Aide-mémoire des formules 18

Annexe B — Repères des paramètres et plages valides 18

Annexe C — Modèles 19

Annexe D — Réponses aux questions d'autovérification 20

Annexe E — Glossaire 21

Comment utiliser ce cahier

Ces laboratoires vous apprennent à réaliser, étape par étape, une évaluation des risques de cybersécurité fondée sur des scénarios de risque avec CyberRiskGuardian (CRG), à partir d'une seule organisation fictive : **MediBec**, un centre médical privé comptant dix cliniques au Québec. L'évaluation complète de MediBec est publiée avec CyberRiskGuardian; vous pouvez donc comparer votre travail avec celle-ci. Votre travail noté portera sur un cas *différent*.

Chaque laboratoire présente ses objectifs, sa durée, le matériel requis, les étapes, le livrable et trois questions pour vérifier votre compréhension. Les réponses à ces questions se trouvent à l'annexe D. Travaillez dans le parcours d'outils choisi par votre enseignant :

- **Parcours A — Claude** : le plugiciel ou le projet CyberRiskGuardian dans Claude.
- **Parcours B — Application de bureau** : l'application de bureau CyberRiskGuardian dans votre navigateur.
- **Parcours C — Excel** : le classeur CyberRiskGuardian (feuilles Analyse, S1–S10, M1–M10).

Lorsqu'une étape diffère selon le parcours, elle est marquée **[A]**, **[B]** ou **[C]**.

Cinq règles pour chaque laboratoire

1. **Utilisez le cas comme source des faits.** Si vous avez besoin d'un fait que le cas ne fournit pas, indiquez-le, formulez une hypothèse raisonnable et expliquez ce qui changerait si elle était fausse.
2. **Étiquetez ce que vous estimez.** Chaque nombre estimé par vous ou par un outil d'IA porte la mention **Estimation analytique — validation requise**. Chaque fait manquant porte la mention **Lacune d'information — validation organisationnelle requise**. Chaque choix qui relève de la direction porte la mention **Décision de la direction requise**.
3. **Laissez le moteur calculer.** Les résultats finaux proviennent du calculateur vérifié (application de bureau, `crg_calc.py` ou classeur recalculé), jamais de l'arithmétique d'une IA.
4. **Vérifiez les résultats de l'IA.** Les outils d'IA inventent des normes, des identifiants de contrôles, des lois, des statistiques et des vecteurs CVSS qui semblent exacts. Vérifiez chacun d'eux auprès d'une source primaire avant de l'utiliser.
5. **Protégez les données.** Ne collez pas de documents confidentiels dans un service d'IA à moins d'y être autorisé. MediBec est fictive et peut être utilisée sans risque.

Laboratoire 0 — Prise en main

Objectifs : installer ou ouvrir votre parcours; confirmer que le moteur de calcul est exact; apprendre les trois mentions. **Durée :** 30 minutes.

Étapes

1. Installez ou ouvrez votre parcours.
   - **[A]** Dans Claude Code : `/plugin install cyberriskguardian --marketplace ITriskMgr/CyberRiskGuardian`, puis `/plugin install crg-governance-textbook --marketplace ITriskMgr/CyberRiskGuardian`. Exécutez une fois `pip install cvss "mcp>=1.2"`, redémarrez et approuvez le serveur `crg-calculator`.
   - **[B]** Décompressez l'application de bureau, puis double-cliquez sur `start.command` (macOS, Linux) ou `start.bat` (Windows). Laissez la fenêtre du terminal ouverte. L'application s'ouvre à

`http://localhost:8099`. Utilisez toujours cette même adresse : votre travail est conservé par votre navigateur pour cette adresse exacte.

- **[C]** Ouvrez le modèle vierge `templates/CyberRiskGuardian_Excel_Model_Blank_v2-4e.xlsx` (ou la copie que votre enseignant vous a remise) et enregistrez-en une copie au nom de votre équipe. Il s'ouvre en mode de calcul manuel : appuyez sur **F9** (Formules → Calculer maintenant) avant de lire quelque nombre que ce soit.

2. Vérifiez le moteur.
   - **[A]** Exécutez `python3 crg_calc.py medibec30.json` à partir du dossier `crg-quantify/scripts` du plugiciel sur l'exemple MediBec. Il doit afficher **risque estimé total 84 491** et **résiduel 41 104**.
   - **[B]** Le bas de la barre latérale gauche doit afficher **moteur vérifié · 84 491 / 41 104**.
   - **[C]** Votre enseignant vous donnera les données d'entrée d'un scénario de risque et le résultat attendu; saisissez-les et comparez.
3. **[B]** Ouvrez l'espace de travail MediBec, puis **Processus** (premier élément du menu). Lisez les treize étapes d'une évaluation complète.
4. Relisez les trois mentions dans les « Cinq règles » ci-dessus. Trouvez un exemple de chacune dans les livrables d'exemple ou l'espace de travail MediBec.

Livrable : une capture d'écran du moteur vérifié (ou du résultat de votre calculateur), avec votre nom et la date.

Vérifiez votre compréhension

0.1. Pourquoi ne devriez-vous vous fier à aucun nombre tant que le moteur n'a pas été vérifié?

0.2. Dans l'application de bureau, pourquoi vos espaces de travail pourraient-ils sembler disparaître si vous ouvrez l'application à `127.0.0.1:8099` au lieu de `localhost:8099`?

0.3. Quelle mention utiliseriez-vous pour « Le fournisseur du DME de MediBec n'est pas nommé dans le cas »?

Laboratoire 1 — Contexte organisationnel et joyaux de la couronne

Objectifs : décrire, à partir du cas, la mission, les processus critiques et les dépendances de MediBec; déterminer ses joyaux de la couronne (actifs critiques); distinguer les faits des hypothèses. **Durée :** 60 minutes. **Intrant :** étude de cas MediBec, sections 3 à 5.

Mise en contexte

Une évaluation des risques part de l'organisation, et non d'une liste de menaces. Vous devez savoir ce que fait MediBec, quels processus importent le plus, de quels actifs ces processus dépendent et ce que vous ne savez *pas* encore.

Étapes

1. Lisez les sections 3 à 5 du cas. Dressez la liste des faits sur lesquels vous vous appuierez, chacun avec son numéro de section. Exemple : *« 10 cliniques à Montréal, Québec, Gatineau et Saguenay (s. 3). »*
2. Remplissez le tableau de contexte ci-dessous. Limitez chaque cellule à 40 mots.

Élément de contexte	MediBec (avec source)
Mission	
Secteur et taille	
Processus d'affaires critiques	
Systèmes et applications critiques	
Infrastructure et infonuagique	
Informations sensibles	
Fournisseurs et partenaires	
Contexte juridique et réglementaire (tel que le cas l'énonce)	
Exigences de disponibilité	
Contrôles existants	
Historique des incidents	
Capacité en cybersécurité	

3. Retracez une chaîne : **Objectif → Processus → Actif principal → Actifs de soutien → Dépendances → Conséquence en cas de perte.** Exemple de départ : *Continuité des soins → documentation clinique → DME → identité, centre de données de Montréal, réseau étendu (WAN) → …*
4. Déterminez **cinq ou six joyaux de la couronne** : les actifs ou services dont la perte nuirait le plus à la mission. Pour chacun, indiquez un responsable métier, l'importance de la confidentialité, de l'intégrité et de la disponibilité (Élevée / Très élevée) et ses principales dépendances.
5. Énumérez au moins trois **lacunes d'information** (faits dont vous auriez besoin mais que le cas ne fournit pas) et deux **hypothèses** que vous formulez, chacune avec sa mention.
    - **[A]** Demandez à l'assistant d'effectuer la collecte du contexte à partir du document du cas. Comparez ses joyaux de la couronne avec les vôtres; ne conservez que ce que le cas appuie.
    - **[B]** Organisation → Espaces de travail → *Nouvel espace de travail* (type *Cas d'affaires pour la classe*), déposez le document du cas, cochez *Extraire le profil et l'appétit* et *Puis extraire les actifs essentiels*, choisissez **Règles seulement (sans IA, hors ligne)**. Examinez chaque valeur proposée et son étiquette (FACT, INFERENCE, ASSUMPTION, EXTERNAL, UNKNOWN). Résolvez à partir du cas les valeurs UNKNOWN que vous pouvez.

Livrable : le tableau de contexte, une chaîne de dépendances, la liste des joyaux de la couronne et la liste des lacunes et hypothèses (deux pages au maximum).

Vérifiez votre compréhension

1.1. Pourquoi « l'identité et l'accès à distance » constitue-t-il un joyau de la couronne même s'il ne contient pas lui-même de données sur les patients?

1.2. Le cas indique que MediBec a subi « de multiples tentatives d'attaque infructueuses depuis 2020 ». S'agit-il d'un fait, d'une inférence ou d'une hypothèse? Que ne pouvez-vous *pas* en conclure?

1.3. Nommez une dépendance qui constitue un point de défaillance unique pour plusieurs joyaux de la couronne.

Laboratoire 2 — Appétence pour le risque

Objectifs : estimer et justifier une appétence pour le risque de cybersécurité sur une échelle de 0 à 1; distinguer l'appétence, la tolérance et le score de risque. **Durée :** 45 minutes. **Intrant :** section 8 du cas (énoncé d'appétence pour le risque); votre contexte du laboratoire 1.

Mise en contexte

L'appétence exprime le niveau de risque de cybersécurité que la direction est prête à rechercher ou à conserver. CRG utilise les repères suivants :

Valeur	Signification
0,1–0,2	Très forte aversion au risque — très faible appétence
0,3	Faible appétence
0,5	Neutralité face au risque, appétence modérée
0,7	Appétence relativement élevée
0,8–0,9	Très forte appétence

Les valeurs de 0,1 et de 0,9 sont des extrêmes qui ne devraient normalement pas être utilisés.

Étapes

1. Repérez ce que le cas énonce. L'énoncé d'appétence de MediBec indique une **tolérance normalisée de 0,40**, une faible appétence pour ce qui touche la sécurité des patients, la confidentialité des données de santé, la conformité et la confiance du public, ainsi que des seuils de remontée (risque résiduel supérieur à 0,25 pour un examen par la haute direction, supérieur à 0,40 pour une acceptation par le conseil d'administration).
2. Tenez compte des facteurs : secteur, mission, sensibilité des informations, exigences réglementaires, impact potentiel sur les personnes (patients), dépendance à la technologie, capacité financière, tolérance aux perturbations, réputation.
3. Choisissez une valeur. Vous pouvez conserver la valeur de 0,40 du cas ou en proposer une autre; dans les deux cas, justifiez-la en cinq à huit phrases. L'évaluation publiée de MediBec a utilisé **0,30** (une estimation de l'analyste inférieure à la valeur énoncée de 0,40, en raison de la sécurité des patients et de la sensibilité des données de santé). Expliquez si vous êtes d'accord.
4. Consignez la valeur avec sa mention : si elle diffère de celle du cas, il s'agit d'une **Estimation analytique — validation requise**, et le choix final relève d'une **Décision de la direction requise**.
   - **[A]** Demandez : « *Estime l'appétence pour le risque de cybersécurité de MediBec sur une échelle de 0 à 1, avec la justification.* » Comparez la réponse avec l'énoncé du cas; n'acceptez pas une valeur que vous ne pouvez pas justifier vous-même.
   - **[B]** Organisation → Profil et appétit : saisissez l'appétence et sa justification. L'*estimateur de l'appétit* au bas de la page propose une valeur à partir des facteurs cochés.
   - **[C]** Saisissez l'appétence dans la feuille Analyse (cellule E14 du modèle standard).

Livrable : la valeur d'appétence et sa justification (une demi-page).

Vérifiez votre compréhension

2.1. Une appétence de 0,30 est-elle « plus prudente » ou « moins prudente » qu'une appétence de 0,40? Qu'arrive-t-il au risque toléré lorsque l'appétence diminue?

2.2. Pourquoi est-ce une erreur de laisser l'appétence par défaut du classeur sans justification?

2.3. L'appétence est de 0,30 et le risque estimé d'un scénario de risque est de 6 467. Pouvez-vous dire si le scénario est acceptable à partir de ces deux seuls nombres? Pourquoi pas?

Laboratoire 3 — Rédaction de scénarios de risque

Objectifs : rédiger des scénarios de risque sous forme de chaînes causales complètes; générer 20 candidats et sélectionner les 10 plus significatifs; éviter les doublons et les simples noms de menaces. **Durée :** 90 minutes. **Intrant :** contexte et joyaux de la couronne du laboratoire 1; section 9 du cas (bibliothèque de scénarios), à titre d'inspiration seulement.

Mise en contexte

Un scénario de risque n'est pas un nom de menace. C'est une chaîne causale :

> ***Source ou événement de menace → vulnérabilité ou faiblesse → actif ou processus touché → événement de cybersécurité → conséquence organisationnelle.***

Utilisez la structure de phrase suivante :

> *Parce que [source ou événement de menace] peut exploiter [faiblesse] touchant [actif ou processus], [événement indésirable] peut survenir, entraînant [conséquences] et compromettant [objectif].*

Faible : « Rançongiciel. » **Solide :** « Un affilié de rançongiciel utilise des identifiants VPN volés et l'absence d'authentification multifacteur (MFA) sur l'accès à distance pour chiffrer les serveurs de prise de rendez-vous cliniques, ce qui interrompt les rendez-vous dans tous les sites pendant plusieurs jours. »

Étapes

1. Générez **20 scénarios de risque candidats** pour MediBec. Répartissez-les entre : identité, rançongiciels, infonuagique, tiers, initiés, applications et API, infrastructure, postes de travail, dispositifs médicaux, protection des renseignements personnels, fraude, résilience et reprise. Utilisez au moins trois stratégies de génération : à partir des joyaux de la couronne (descendante), à partir des faiblesses que révèle le cas (ascendante), à partir des menaces actives contre le secteur de la santé (axée sur la menace).
2. Pour chaque candidat, rédigez une phrase selon la structure causale et indiquez la dimension CID (confidentialité, intégrité, disponibilité) principalement touchée.
3. **Filtrez** les candidats. Notez chacun de 1 à 5 selon quatre critères : criticité pour l'organisation, pertinence de la menace, exposition, impact potentiel. Ajoutez un **indicateur de remontée** lorsque le scénario pourrait toucher la sécurité des patients, détruire les sauvegardes ou causer une perte de données catastrophique — de tels scénarios ne peuvent pas être écartés en raison de leur seule faible probabilité.
4. **Regroupez.** Fusionnez les variantes d'une même exposition (par exemple trois scénarios d'hameçonnage qui ne diffèrent que par le service visé).
5. **Sélectionnez-en dix.** Ne prenez pas simplement les dix totaux les plus élevés : vérifiez que le portefeuille couvre des actifs, des acteurs et des conséquences variés, et qu'aucune technique unique ne domine.

Pour chaque scénario retenu, répondez à la question : *Pourquoi celui-ci, et non le plus solide des scénarios écartés?*

6. Développez **un** scénario retenu de façon complète : nom, parties prenantes, source de la menace, événement déclencheur, vulnérabilités, actifs et processus touchés, contrôles existants (uniquement ceux dont le cas fait état), séquence d'événements (cinq à huit étapes), conséquences (confidentialité, intégrité, disponibilité, opérations, finances, réglementation, réputation, vie privée, sécurité des personnes), hypothèses.
   - **[A]** `/select-scenarios` exécute la procédure complète de filtrage (sections A à E). Vous pouvez aussi demander 20 candidats, puis remettre chacun en question : « *Quelle étape de cette chaîne le cas appuie-t-il?* »
   - **[B]** Scénarios en lot → *Modèles de menace × actifs* → cochez les modèles, *Cocher les actifs essentiels + les 5 plus critiques*, réglez le *Nombre de candidats* à 20, **Générer des candidats**. Modifiez les noms et les énoncés dans la grille, cochez-en dix et **Ajouter les … sélectionnés au registre**. Facultatif : Ontologie · CRGO → *Suggérer des scénarios* pour voir les scénarios connexes de la bibliothèque.

Livrable : les 20 candidats avec leurs notes, vos dix scénarios retenus avec une justification d'une ligne chacun, et un scénario entièrement développé (modèle de l'annexe C).

Vérifiez votre compréhension

3.1. Réécrivez « Fuite de données chez MediBec » sous forme de scénario de risque à chaîne causale.

3.2. Pourquoi un scénario de faible probabilité qui pourrait détruire toutes les sauvegardes doit-il demeurer sur la liste?

3.3. Deux de vos scénarios sont « hameçonnage du personnel des cliniques » et « hameçonnage du personnel de la facturation ». Devriez-vous conserver les deux? Qu'est-ce qui justifierait de les garder distincts?

Laboratoire 4 — Quantification d'un scénario de risque

Objectifs : estimer les six paramètres CRG d'un scénario de risque, chacun avec une valeur, une justification, des éléments probants et un niveau de confiance. **Durée :** 75 minutes. **Intrant :** votre scénario développé au laboratoire 3 (ou le scénario S1 de MediBec, ci-dessous).

Les six paramètres

Symbole	Nom	Ce qu'il mesure	Faible (≈ 0,2–0,35)	Élevé (≈ 0,65–0,85+)
Pb(A)	Présence de la menace	Cette menace agira-t-elle contre MediBec au cours des 12 prochains mois?	Acteur rare, nécessite une position particulière	Observée ou constante (hameçonnage, balayage)
Pb(ψ,A)	Probabilité d'exploitation	Si elle agit, franchira-t-elle cette faiblesse, compte tenu des contrôles existants?	Contrôles solides et démontrés	Faiblesse démontrée (notification MFA approuvée, alerte fermée)

Symbole	Nom	Ce qu'il mesure	Faible (≈ 0,2–0,35)	Élevé (≈ 0,65–0,85+)
δe	Dommage estimé	Préjudice raisonnablement attendu	Dossiers limités, un seul site	À l'échelle du réseau, plusieurs sites
δm	Dommage maximal	Préjudice plausible dans le pire des cas	—	Impact sur la sécurité des personnes, perte de données catastrophique
θ	Résilience organisationnelle	Capacité de prévenir, détecter, contenir, intervenir, rétablir et poursuivre les activités (plus élevé est meilleur)	Aucune reprise testée, petite équipe	Reprise testée, détection 24 h/24, 7 j/7
μ(E)	Criticité	Importance du service touché pour la mission	Processus de soutien	Essentiel à la mission (prestation des soins, identité)

Règles : chaque valeur se situe entre 0 et 1; δm est au moins égal à δe; θ n'est jamais nul; Pb(A) et Pb(ψ,A) sont estimés séparément; μ(E) n'est pas une seconde estimation du dommage.

Exemple résolu — MediBec S1

S1 : Compromission des comptes d'administrateurs cliniques par hameçonnage et fatigue MFA. Un acteur motivé par l'appât du gain hameçonne les administrateurs des cliniques au moyen d'un leurre sur le thème du DME, capture leurs identifiants et obtient l'approbation d'une notification MFA, ce qui lui donne un accès à distance au DME, à la facturation et aux systèmes administratifs.

Paramètre	Valeur	Justification (abrégée)	Éléments probants	Confiance
Pb(A)	0,85	L'hameçonnage est constant et les tentatives augmentent; des leurres ont déjà été observés	Cas, s. 5; éléments probants de l'exercice	Moyenne
Pb(ψ,A)	0,55	La MFA par notification peut être contournée par la fatigue; aucun accès conditionnel ni blocage des macros n'est démontré	Éléments probants de l'exercice	Faible
δe	0,55	Accès à un sous-ensemble de dossiers; confinement possible si l'attaque est détectée	Cas, s. 3	Moyenne
δm	0,85	Accès complet au DME, ou pivot vers un rançongiciel	Cas, s. 3	Moyenne
θ	0,40	Équipe de sécurité de deux personnes; triage des alertes faible; intervention en cas d'incident non testée	Cas, s. 4	Moyenne
μ(E)	0,85	L'identité est la porte d'entrée vers chacun des joyaux de la couronne	Cas, s. 4	Élevée

Les six valeurs sont des **Estimations analytiques — validation requise.**

Étapes

1. Reprenez votre scénario développé au laboratoire 3.
2. Estimez chacun des six paramètres. Pour chacun, rédigez une ou deux phrases de justification, citez la section du cas (ou signalez la lacune) et indiquez un niveau de confiance : Élevé, Moyen ou Faible.
3. Nommez les **deux ou trois valeurs dont vous êtes le moins sûr**, ainsi que les éléments probants qui permettraient de trancher (une entrevue, un examen des journaux, un test de restauration, un contrat de fournisseur…).
   - **[A]** Demandez à l'assistant une *critique des paramètres* de vos valeurs. N'acceptez une modification que si vous pouvez la défendre vous-même.
   - **[B]** Éditeur de scénarios → *Quantification* : saisissez la valeur, la justification, les éléments probants et le niveau de confiance pour chaque paramètre.
   - **[C]** Saisissez les valeurs dans la feuille S du scénario; recalculez (F9).

Livrable : le tableau des paramètres de votre scénario, avec les valeurs les plus incertaines indiquées.

Vérifiez votre compréhension

4.1. Pourquoi le fait de fusionner Pb(A) et Pb(ψ,A) en une seule « vraisemblance » entraînerait-il un double comptage?

4.2. Un coéquipier fixe θ = 0,90 « parce que MediBec a des pare-feu et un antivirus ». Qu'est-ce qui cloche dans ce raisonnement?

4.3. Pourquoi δm doit-il être au moins égal à δe?

Laboratoire 5 — CVSS v4.0 pour un scénario de risque

Objectifs : coter une vulnérabilité définie avec le score de base CVSS v4.0; comprendre ce que le CVSS mesure et ne mesure pas. **Durée :** 60 minutes.

Mise en contexte

Le CVSS (Common Vulnerability Scoring System) mesure la **gravité technique d'une vulnérabilité**. CRG utilise le score de base CVSS v4.0 comme multiplicateur dans la formule de risque. Ce n'est pas une mesure du risque organisationnel : un CVSS élevé ne signifie pas le risque d'affaires le plus élevé.

Pour les scénarios de risque non techniques (hameçonnage, utilisation abusive par un initié, fraude, lacunes de gouvernance), cotez une **faiblesse représentative** (par exemple « MFA par notification sur un seul canal ») et qualifiez le score d'*applicabilité limitée* — ou expliquez pourquoi le CVSS ne s'applique pas.

Les métriques de base

Groupe	Métrique	Valeurs
Exploitabilité	Vecteur d'attaque (AV)	Réseau, Adjacent, Local, Physique
	Complexité de l'attaque (AC)	Faible, Élevée

Groupe	Métrique	Valeurs
	Exigences de l'attaque (AT)	Aucune, Présentes
	Privilèges requis (PR)	Aucun, Faibles, Élevés
	Interaction de l'utilisateur (UI)	Aucune, Passive, Active
Impact sur le système vulnérable	Confidentialité, intégrité, disponibilité (VC, VI, VA)	Élevé, Faible, Aucun
Impact sur les systèmes subséquents	Confidentialité, intégrité, disponibilité (SC, SI, SA)	Élevé, Faible, Aucun

Exemple résolu — MediBec S1

Faiblesse représentative : MFA par notification sans correspondance de nombres sur l'accès à distance.

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:H/VI:H/VA:N/SC:H/SI:L/SA:L` → **9,3 (Critique)**

Métrique	Valeur	Justification
AV	Réseau	Le portail d'accès à distance est accessible par Internet
AC	Faible	Aucune condition particulière au-delà de la trousse d'hameçonnage
AT	Aucune	Aucun prérequis propre au déploiement
PR	Aucun	L'attaquant part sans compte
UI	Active	Un utilisateur doit saisir ses identifiants et approuver la notification
VC / VI	Élevé / Élevé	Contrôle complet de la session compromise
VA	Aucun	La disponibilité de la passerelle n'est pas touchée
SC	Élevé	L'accès s'étend aux dossiers des patients dans le DME
SI / SA	Faible / Faible	Effet limité en aval sur l'intégrité et la disponibilité

Étapes

1. Définissez, en une phrase, la vulnérabilité unique dont dépend votre scénario de risque.
2. Choisissez chaque métrique de base et justifiez-la en une ligne.
3. Calculez le score avec un calculateur — ne l'estimez jamais à l'œil.
   - **[A]** `/crg-calc` ou l'outil `cvss4_score` du serveur `crg-calculator`.
   - **[B]** Outils → *CVSS v4.0* : collez ou construisez le vecteur, puis enregistrez-le dans le scénario.
   - **[C]** Utilisez le calculateur CVSS v4.0 de FIRST et saisissez le score dans la feuille Analyse; conservez la chaîne du vecteur à côté.
4. Rédigez une phrase sur les limites du score pour votre scénario.

Livrable : le vecteur, le score et la justification des métriques.

Vérifiez votre compréhension

5.1. Faites passer l'interaction de l'utilisateur de S1 d'Active à Aucune. Vous attendez-vous à ce que le score augmente ou diminue? Pourquoi est-ce logique?

5.2. Pourquoi devez-vous conserver la chaîne complète du vecteur, et non seulement le score?

5.3. Donnez un scénario de risque de MediBec pour lequel le CVSS n'a qu'une applicabilité limitée, et expliquez.

Laboratoire 6 — Calcul et interprétation du risque

Objectifs : calculer le risque estimé et le risque toléré; interpréter le résultat par rapport à la tolérance; expliquer ce qui détermine le verdict. **Durée :** 45 minutes.

Les formules

```
Risque estimé  Re = Pb(A) × Pb(ψ,A) × CVSS × ((δe + δm) / 2) × μ(E) ÷ θ × Facteur
Risque toléré  Rt = Pb(A) × Pb(ψ,A) × CVSS × Appétence × μ(E) ÷ θ × Facteur
```

Le facteur (1 000 dans l'évaluation de MediBec) ne sert qu'à mettre les nombres à l'échelle. Les scores de risque sont des **indicateurs relatifs** servant à la comparaison et à la priorisation; ce ne sont ni des dollars ni des prédictions de pertes.

Exemple résolu — MediBec S1 (appétence 0,30, facteur 1 000)

```
Re = 0,85 × 0,55 × 9,3 × ((0,55 + 0,85) / 2) × 0,85 ÷ 0,40 × 1 000 = 6 467
Rt = 0,85 × 0,55 × 9,3 × 0,30 × 0,85 ÷ 0,40 × 1 000          = 2 772
Ratio avant traitement = Re ÷ Rt = 2,33  →  au-dessus de la tolérance avant traitement
```

Remarquez que le ratio avant traitement correspond simplement à **dommage moyen ÷ appétence** = 0,70 ÷ 0,30 = 2,33. Tout le reste s'annule.

Étapes

1. Calculez Re et Rt pour votre scénario de risque à la main (montrez chaque multiplication), puis avec le moteur. Les deux résultats doivent concorder à l'unité près.
   - **[A]** `/crg-calc` avec les six paramètres, le vecteur CVSS, l'appétence et le facteur.
   - **[B]** Calculateur de risque → cliquez sur la ligne de votre scénario pour voir chaque étape de la formule.
   - **[C]** Recalculez (F9); lisez les colonnes L (risque estimé) et M (risque toléré) de la feuille Analyse. **Ne vous fiez pas à la couleur rouge de la cellule** : comparez L et M numériquement.
2. Calculez le ratio avant traitement et vérifiez qu'il est égal à dommage moyen ÷ appétence.
3. Refaites l'exercice avec l'appétence énoncée dans le cas (0,40). Qu'est-ce qui change et qu'est-ce qui ne change pas?
4. **[B]** Examinez l'ensemble du registre de MediBec (30 scénarios). Classez-les selon le risque estimé, puis selon le ratio avant traitement. Pourquoi les deux classements diffèrent-ils?

Livrable : votre calcul présenté étape par étape, le résultat du moteur et une interprétation en trois phrases.

Vérifiez votre compréhension

6.1. Le scénario X a Pb(A) = 0,9 et le scénario Y a Pb(A) = 0,2. Tous leurs autres paramètres sont égaux. Lequel a le risque estimé le plus élevé? Lequel a le ratio avant traitement le plus élevé?

6.2. Qu'arrive-t-il à Re et à Rt si vous faites passer le facteur de 1 000 à 10 000? Et au ratio?

6.3. Pourquoi « risque estimé = 6 467 » n'est-il pas un montant en dollars?

Laboratoire 7 — Traitement, contrôles partagés et risque résiduel

Objectifs : concevoir un ensemble de mesures de traitement lié à la chaîne causale; estimer les réductions de probabilité et d'impact; calculer le risque résiduel; éviter le double comptage des contrôles partagés. **Durée :** 90 minutes.

Les formules

```
Risque atténué  = Re × Réduction de la probabilité × Réduction de l'impact
Risque résiduel = Re − Risque atténué
Ratio           = Résiduel ÷ Toléré
```

Interprétez le ratio ainsi : **inférieur à 0,90** sous la tolérance · **0,90–1,10** approximativement à la tolérance · **supérieur à 1,10** au-dessus de la tolérance.

L'atténuation est **multiplicative** : une réduction de 80 % de la probabilité et une réduction de 80 % de l'impact éliminent 64 % du risque. Un ensemble de mesures qui ne réduit que la probabilité, ou que l'impact, n'atténue rien selon cette convention. Pour ramener un scénario de risque sous la tolérance, il faut P × Q ≥ 1 − appétence ÷ dommage moyen.

Exemple résolu — MediBec S1

Ensemble de mesures : MFA résistante à l'hameçonnage et accès conditionnel (I01), gestion des accès privilégiés (I02), détection et intervention gérées 24 h/24, 7 j/7 (I03), sensibilisation (I12). Réduction de la probabilité 0,80, réduction de l'impact 0,75.

```
Atténué  = 6 467 × 0,80 × 0,75 = 3 880
Résiduel = 6 467 − 3 880       = 2 587
Ratio    = 2 587 ÷ 2 772        = 0,93  →  approximativement à la tolérance
```

Vérification : 1 − 0,30 ÷ 0,70 = 0,571; P × Q = 0,60 ≥ 0,571, de sorte que le risque résiduel se situe tout juste à l'intérieur de la plage « approximativement à la tolérance ».

Étapes

1. Pour votre scénario de risque, énumérez **trois à cinq mesures**. Pour chacune, précisez : quelle étape de la chaîne causale elle interrompt; ce qu'elle ajoute aux contrôles déjà en place; son responsable; son coût ponctuel et son coût récurrent (en dollars canadiens, sur un horizon unique de 12 mois); son délai avant bénéfice.
2. Estimez la réduction de la probabilité et la réduction de l'impact de l'ensemble de mesures (chacune entre 0 et 1) et justifiez-les.
3. Calculez le risque atténué, le risque résiduel et le ratio.

4. **Contrôles partagés.** Déterminez lesquelles de vos mesures servent aussi d'autres scénarios. Répartissez leur coût entre ces scénarios (une répartition égale est acceptable) et notez que le total du portefeuille compte chaque initiative une seule fois.
5. Si le scénario demeure au-dessus de la tolérance : énoncez les options — atténuer davantage, **transférer** (assurance, contrat), **éviter** (cesser l'activité) ou **accepter** formellement — et qui doit décider.
   - **[B]** Atténuation des risques → *Propositions* ou *Catalogue de contrôles*; fixez les coûts et rp / ri; **Appliquer**. Recommandations → *Besoin de traitement* affiche le verdict pour chaque scénario.
   - **[C]** Sélectionnez les contrôles dans la feuille M. **Avertissement :** le modèle additionne les coefficients des contrôles (0,06 chacun par défaut), de sorte qu'une vingtaine de contrôles dépassent 1 et que le risque résiduel *augmente*. Maintenez chaque réduction entre 0 et 1.

Livrable : le tableau de traitement, le calcul du risque résiduel et la décision requise.

Vérifiez votre compréhension

7.1. Un ensemble de mesures a une réduction de la probabilité de 0,90 et une réduction de l'impact de 0,00. Quel est le risque atténué? Qu'est-ce que cela vous apprend sur la conception de l'ensemble?

7.2. La MFA sert sept scénarios de MediBec et coûte 180 000 $ une seule fois. Comment son coût devrait-il apparaître dans chaque scénario et dans le portefeuille?

7.3. Pourquoi le fait de recommander un contrôle « que l'organisation possède déjà » ne peut-il jamais réduire le risque?

Laboratoire 8 — Sensibilité et incertitude

Objectifs : vérifier comment la conclusion change lorsque vos estimations changent; déterminer les décisions qui dépendent de valeurs incertaines. **Durée :** 45 minutes.

Mise en contexte

Vos paramètres sont des estimations. La question n'est pas « quel est le risque exact? », mais « la décision change-t-elle si je me trompe? ». La convention de CRG construit trois cas : faire varier Pb(A), Pb(ψ,A), δe et δm de ∓0,10 / ±0,10, θ de ±0,10 / ∓0,10, et les deux réductions de ±0,10 / ∓0,10, en maintenant chaque valeur entre 0,05 et 0,99.

Exemple résolu — MediBec S1

Cas	Estimé	Toléré	Résiduel	Ratio	Verdict
Inférieur (optimiste)	3 202	1 601	752	0,47	Sous la tolérance
Central	6 467	2 772	2 587	0,93	Approximativement à la tolérance
Supérieur (pessimiste)	13 017	4 881	7 094	1,45	Au-dessus de la tolérance

Le verdict change d'un cas à l'autre : S1 est un scénario de risque pour lequel **de meilleurs éléments probants valent la peine d'être payés** (par exemple, vérifier si les utilisateurs approuvent les notifications MFA) avant l'investissement ou en parallèle.

Étapes

1. Construisez les cas inférieur, central et supérieur pour votre scénario.
2. Le verdict change-t-il? S'il est « au-dessus de la tolérance » même dans le cas inférieur, le scénario nécessite un transfert ou une acceptation formelle, et non seulement davantage de dépenses.
3. Déterminez le paramètre dont la variation modifie le plus le résultat. **[B]** Prévisions → *Facteurs déterminants* (diagramme en tornade); *Monte-Carlo* convertit vos niveaux de confiance en plages.
4. Rédigez deux phrases à l'intention de la direction : ce dont vous êtes certain et quels éléments probants changeraient la recommandation.

Livrable : le tableau des trois cas et l'énoncé de deux phrases.

Vérifiez votre compréhension

8.1. Dans l'exemple de S1, quelle décision de la direction changerait entre le cas inférieur et le cas supérieur?

8.2. Une prévision donne un intervalle étroit. Cela signifie-t-il que vos estimations sont exactes?

8.3. Pourquoi une diminution de θ fait-elle augmenter à la fois le risque estimé et le risque toléré, mais laisse-t-elle le ratio inchangé?

Laboratoire 9 — Indicateurs clés de risque

Objectifs : définir des indicateurs clés de risque (ICR) mesurables qui indiquent à la direction si un risque évolue.
Durée : 45 minutes.

Mise en contexte

Un ICR n'est utile que si quelqu'un peut le mesurer, à partir d'une source nommée, selon un calendrier, par rapport à des seuils qui déclenchent une action.

Exemple résolu — MediBec

ICR	Risque visé	Mesure	Source	Responsable	Fréquence	Cible	Avertissement	Critique
ICR-01 % des comptes privilégiés et d'accès à distance protégés par une MFA résistante à	S1, S8, S9	Comptes FIDO2 ÷ compt	Rapport du fournisseur d'identité	Responsable de la cybersécurité	Mensuelle	100 %	< 95 %	< 85 %

ICR	Risque visé	Mesure	Source	Responsable	Fréquence	Cible	Avertissement	Critique
l'hameçonnage		es visés						
ICR-05 Réussite des tests de restauration des sauvegardes des joyaux de la couronne dans le RTO	S2, S3, S10	Tests réussis ÷ tests effectués	Plateforme de sauvegarde, registres de reprise après sinistre	DPI (Infrastructure)	Trimestrielle	100 %	< 95 %	< 80 %

Étapes

1. Définissez **trois ICR** pour vos principaux scénarios de risque, en remplissant chaque colonne du tableau ci-dessus.
2. Pour chaque ICR, indiquez ce que la direction devrait faire lorsque le seuil d'avertissement est franchi.
3. **[B]** Tableau de bord des ICR → *Enregistrer une mesure*. Après quatre relevés, Prévisions → *Projections des ICR* indique si un seuil sera franchi.

Livrable : trois ICR complets.

Vérifiez votre compréhension

9.1. Qu'est-ce qui cloche avec l'ICR « la sécurité s'améliore »?

9.2. Pourquoi un indicateur pour lequel « une valeur plus basse est meilleure » doit-il avoir des seuils formulés avec « supérieur à »?

9.3. Combien de relevés l'application de bureau exige-t-elle avant de projeter la tendance d'un ICR, et pourquoi refuse-t-elle de le faire avec moins de relevés?

Laboratoire 10 — La note de service à la direction

Objectifs : rédiger une note de service d'une page, axée sur la décision, à l'intention de la haute direction. **Durée :** 60 minutes.

Ce que fait une note de service solide

- Elle **commence par la décision** que la direction doit prendre.
- Elle indique combien de scénarios de risque sont au-dessus de la tolérance **avant et après** le traitement.
- Elle présente le **coût du portefeuille recommandé** par rapport au contexte budgétaire.
- Elle précise le **risque résiduel** qui demeure et qui doit l'accepter formellement.
- Elle nomme les **deux ou trois principales incertitudes** et les prochaines étapes.
- Elle **ne reprend pas** les tableaux. Elle concorde avec le classeur à l'unité près.

Points de référence de MediBec

L'évaluation publiée de 30 scénarios a établi ce qui suit : après traitement, 12 scénarios au-dessus de la tolérance, 11 approximativement à la tolérance et 7 sous la tolérance; risque estimé total de 84 491 contre un risque résiduel de 41 104 (une réduction de 51 %); dépenses actuelles en cybersécurité d'environ 0,9 % du budget des TI, sous le plancher de 4 % de la ligne directrice budgétaire. *Ne copiez pas ces chiffres dans votre propre cas.*

Étapes

1. Rédigez la note de service à l'aide du modèle de l'annexe C.
2. Échangez vos notes avec une autre équipe. Chaque réviseur répond aux questions suivantes : *Qu'est-ce qu'on me demande exactement d'approuver? Le coût est-il clair? Quel chiffre contesterais-je?*
3. Révisez.
   - **[A]** `/qc-review` effectue une revue de qualité indépendante de votre note; `check_labels.py` énumère les mentions manquantes.
   - **[B]** Gouvernance → *Revue de qualité* avant d'exporter quoi que ce soit.

Livrable : une note de service d'une page.

Vérifiez votre compréhension

10.1. Pourquoi le premier paragraphe de la note de service devrait-il énoncer la décision plutôt que la méthode?

10.2. Votre note indique « risque résiduel 41 104 » et votre classeur indique 41 140. Que devriez-vous faire?

10.3. Qui accepte formellement un risque résiduel qui demeure au-dessus de la tolérance?

Laboratoire 11 — Éléments probants des opérations de sécurité (facultatif, parcours application de bureau)

Objectifs : relier les éléments probants des opérations de sécurité aux scénarios de risque sans transformer les alertes en incidents ni les niveaux de confiance en probabilités. **Durée :** 120 minutes. **Prérequis :** l'application de bureau avec la trousse de simulation MediBec chargée par votre enseignant.

Étapes

1. SIEM → *Vue d'ensemble* : réglez la date de référence au **9 octobre 2026**.
2. Effectuez les dix exercices que votre enseignant vous assigne (EX-01 à EX-10) dans le SIEM et le SOAR : ordre de triage, un vrai positif fermé comme bénin, lacunes de couverture, télémétrie muette,

restrictions TLP, un indicateur avec une confiance de 95, un dossier qui peut être ou ne pas être un incident, des actions sans approbation valide, état de préparation des playbooks, lacunes de détection.

3. Scénarios en lot → *Des opérations de sécurité (SIEM et SOAR)*, en date du 9 octobre. **Consigner la preuve dans S2.** Ouvrez S2 dans l'éditeur de scénarios : la fiche *Preuves des opérations de sécurité* l'affiche, et **aucun paramètre n'a changé**.
4. Décidez, en équipe, si les éléments probants justifient une modification de Pb(A), de Pb(ψ,A) ou de θ pour S2. Rédigez la justification. Lancez ensuite Gouvernance → *Revue de qualité*.

Livrable : les réponses aux exercices assignés et la justification relative à S2.

Vérifiez votre compréhension

11.1. Un indicateur porte une confiance de source de 95. Pouvez-vous fixer Pb(A) = 0,95? Pourquoi pas?

11.2. Qu'est-ce qui transforme un dossier SOAR en incident?

11.3. Pourquoi une règle de détection dont la télémétrie requise est muette ne compte-t-elle pas comme couverture?

Laboratoire 12 — Du risque à la politique et à l'audit

Objectifs : utiliser vos résultats d'analyse de risque pour justifier une politique de sécurité et pour prioriser un plan d'audit axé sur les risques. **Durée :** 90 minutes (deux parties).

Partie 1 — Du risque à l'audit

1. Prenez les cinq scénarios de risque de MediBec dont le risque résiduel est le plus élevé. Pour chacun, nommez l'**entité auditable** (un processus, un système ou un fournisseur) et le **contrôle clé** dont dépend le traitement.
2. Pour un contrôle clé, concevez deux tests : un **test de conception** (le contrôle est-il conçu pour fonctionner?) et un **test d'efficacité opérationnelle** sur une période (a-t-il fonctionné?). Précisez la population, la période, l'unité d'échantillonnage, la méthode et la taille de l'échantillon.
3. Proposez une analyse de données (par exemple : comparaison des employés ayant quitté l'organisation avec les comptes actifs), avec les données, la logique de la requête et les étapes de validation des données.

Partie 2 — Du risque à la politique

1. Rédigez la phrase : « *MediBec a besoin d'une politique de gestion des identités et des accès parce que* ___, *et cette politique sera réussie lorsque* ___. » Utilisez S1 et vos résultats.
2. Rédigez cinq énoncés de politique numérotés. Chacun nomme un acteur, utilise **doit** ou **ne doit pas** et énonce un résultat vérifiable. Placez les valeurs techniques (longueur des mots de passe, intervalles de revue) dans une *norme* nommée, et non dans la politique.
3. Définissez un indicateur clé de performance (ICP) pour la politique, avec une cible, un responsable, une source de données et une fréquence.

Livrable : la conception du test d'audit et les cinq énoncés de politique avec un ICP.

Vérifiez votre compréhension

12.1. Pourquoi « l'auditeur a confirmé qu'une politique de revue des accès existe » ne constitue-t-il pas un élément probant que les revues des accès fonctionnent?

12.2. Réécrivez sous forme d'énoncé vérifiable : « Des contrôles de sécurité appropriés devraient être utilisés pour l'accès à distance. »

12.3. Où devrait-on inscrire « les mots de passe doivent comporter au moins 14 caractères », et pourquoi?

Annexe A — Aide-mémoire des formules

```
Risque estimé  Re = Pb(A) × Pb(ψ,A) × CVSS × ((δe + δm) / 2) × μ(E) ÷ θ × Facteur
Risque toléré  Rt = Pb(A) × Pb(ψ,A) × CVSS × Appétence × μ(E) ÷ θ × Facteur
Atténué            = Re × Réduction de la probabilité × Réduction de l'impact
Résiduel           = Re − Atténué
Ratio              = Résiduel ÷ Rt
Coût-efficacité    = (Re − Résiduel) ÷ Coût × 1 000   (unités de risque éliminées par
tranche de 1 000 $)

Simplifications à retenir
Ratio avant traitement = ((δe + δm) / 2) ÷ Appétence
Ratio après traitement = ((δe + δm) / 2) × (1 − P × Q) ÷ Appétence
Sous la tolérance exige  P × Q ≥ 1 − Appétence ÷ ((δe + δm) / 2)
```

Classification : ratio < 0,90 sous la tolérance · 0,90–1,10 approximativement à la tolérance · > 1,10 au-dessus de la tolérance.

Ligne directrice budgétaire (CRG) : dépenses en cybersécurité de **12 %** du budget total des TI (salaires compris) pour une appétence de 0,30 ou moins, de **7,8 %** à 0,50 et de **4 %** à 0,70 ou plus, avec une interpolation linéaire entre ces valeurs.

Annexe B — Repères des paramètres et plages valides

Paramètre	Plage valide	Faible	Modéré	Élevé
Pb(A)	0–1	Acteur ou événement rare	Plausible pour le secteur	Observé ou constant
Pb(ψ,A)	0–1	Contrôles solides et démontrés	Contrôles partiels ou inconnus	Faiblesse démontrée
δe, δm	0–1, δm ≥ δe	Dossiers limités, un seul site	Important, plusieurs sites	À l'échelle du réseau, sécurité des personnes, perte catastrophique
θ	> 0 à 1	Faible : aucune reprise testée	Partielle	Reprise testée, détection 24 h/24, 7 j/7
μ(E)	0–1	Processus de soutien	Processus important	Essentiel à la mission
CVSS	0–10	—	—	—
Réductions	0–1	—	—	—

Paramètre	Plage valide	Faible	Modéré	Élevé
	chacune			

Annexe C — Modèles

C.1 Modèle de développement d'un scénario de risque

Champ	Contenu
Identifiant et nom	
Énoncé causal (une ou deux phrases)	
Parties prenantes	
Source de la menace	
Événement déclencheur	
Vulnérabilités ou conditions prédisposantes	
Actifs touchés	
Processus d'affaires touchés	
Contrôles existants (avec éléments probants)	
Séquence d'événements (5 à 8 étapes)	
Conséquences : C, I, D, opérations, finances, réglementation, réputation, vie privée, sécurité des personnes	
Hypothèses et lacunes d'information (avec mentions)	
Pourquoi ce scénario? (pertinence, éléments probants, actif, faiblesse, conséquence, raisons pour lesquelles il l'emporte sur les scénarios non retenus)	

C.2 Modèle de note de service à la direction

Destinataire : *[Membre de la haute direction]* · ***Expéditeur :*** *[Équipe]* · ***Date :*** · ***Objet :*** *Décision requise — portefeuille de traitement des risques de cybersécurité*

Décision demandée. *[Une ou deux phrases : ce qu'il faut approuver, à quel coût, pour quand.]*

Pourquoi maintenant. *[Combien de scénarios de risque dépassent la tolérance avant traitement; les deux ou trois plus importants, en termes d'affaires.]*

Portefeuille recommandé. *[Les initiatives, le coût ponctuel et récurrent total, comparé au contexte budgétaire.]*

Résultat. *[Combien de scénarios sont sous la tolérance, à la tolérance et au-dessus de la tolérance après traitement; quel risque résiduel demeure.]*

Risque résiduel à accepter. *[Quels scénarios, qui doit les accepter formellement —* ***Décision de la direction requise****.]*

Principales incertitudes et prochaines étapes. *[Les estimations à valider; les éléments probants à recueillir; la date de la prochaine revue.]*

C.3 Déclaration d'utilisation de l'IA générative

J'ai / Nous avons utilisé [nom et version de l'outil] pour [objectif : par exemple, générer des idées de scénarios de risque, proposer des justifications de paramètres, vérifier la grammaire]. J'ai / Nous avons vérifié tous les résultats par rapport au cas et à des sources primaires, recalculé chaque nombre avec le moteur CyberRiskGuardian, révisé le texte, et j'assume / nous assumons la responsabilité de l'ensemble du contenu. [Ou : Aucun outil d'IA générative n'a été utilisé dans ce travail.]

Annexe D — Réponses aux questions d'autovérification

Laboratoire 0. 0.1 Un moteur non vérifié peut calculer différemment de l'implémentation de référence; tout nombre qu'il produit pourrait être erroné sans avertissement. 0.2 Le navigateur conserve les espaces de travail par adresse exacte; `127.0.0.1:8099` et `localhost:8099` sont des adresses différentes. 0.3 **Lacune d'information — validation organisationnelle requise.**

Laboratoire 1. 1.1 Tous les services cliniques et administratifs en dépendent; sa compromission ouvre l'accès à tous les autres joyaux de la couronne. 1.2 C'est un fait énoncé dans le cas. Vous ne pouvez pas conclure que les contrôles ont arrêté les tentatives, que les journaux suffisent à prouver qu'elles ont échoué, ni qu'aucune tentative n'a réussi sans être détectée. 1.3 Le centre de données de Montréal et le nœud central du réseau étendu (WAN), ou le service d'identité et d'annuaire.

Laboratoire 2. 2.1 Plus prudente. Le risque toléré diminue proportionnellement à l'appétence, de sorte qu'un plus grand nombre de scénarios le dépassent. 2.2 La valeur par défaut n'est pas l'appétence de l'organisation; la laisser sans explication signifie que le test de tolérance n'a aucun fondement. 2.3 Non. Il faut le risque toléré de ce scénario (qui dépend de ses propres paramètres) et, après traitement, le risque résiduel.

Laboratoire 3. 3.1 Exemple : « Un acteur externe exploite un emplacement de stockage infonuagique exposé publiquement, utilisé pour le transfert d'images médicales et dépourvu de restrictions d'accès et de journalisation, afin de télécharger des fichiers d'imagerie contenant des identifiants de patients, ce qui cause une atteinte à la vie privée devant être déclarée, des coûts de notification et une perte de confiance des patients. » 3.2 Parce que l'impact pourrait être catastrophique (aucune reprise possible après une attaque destructrice); les scénarios de faible probabilité et à conséquences graves portent un indicateur de remontée et peuvent nécessiter une investigation plutôt qu'une exclusion. 3.3 En général, il faut les fusionner. Ne les gardez distincts que si les actifs, les conséquences, les contrôles, les responsables ou les décisions de traitement diffèrent de façon importante (par exemple, le personnel de la facturation peut détourner des paiements — une conséquence de fraude que le personnel des cliniques ne crée pas).

Laboratoire 4. 4.1 Pb(A) indique déjà si la menace agit; si votre « vraisemblance » inclut aussi la réussite de l'attaque, la multiplier par Pb(ψ,A) compte deux fois la même incertitude. 4.2 Posséder des contrôles n'équivaut pas à de la résilience. θ mesure la capacité démontrée de prévenir, détecter, contenir, intervenir, rétablir et poursuivre les activités; le cas fait état d'une équipe de deux personnes, d'un triage faible et d'une reprise non testée. 4.3 Le dommage maximal correspond au pire cas plausible; le cas attendu ne peut pas le dépasser.

Laboratoire 5. 5.1 Il augmenterait, de 9,3 à 9,9, parce qu'une attaque qui ne nécessite aucune action de l'utilisateur est plus facile à réaliser. 5.2 Le vecteur montre *pourquoi* le score est ce qu'il est, permet à un réviseur de le recalculer et révèle des erreurs qu'un nombre seul dissimule. 5.3 Exemple : S21, divulgation accidentelle par

le personnel — il n'y a aucune vulnérabilité technique à exploiter; tout score ne décrit qu'une faiblesse représentative.

Laboratoire 6. 6.1 X a le risque estimé le plus élevé (4,5 fois celui de Y); leurs ratios avant traitement sont égaux, parce que les probabilités s'annulent dans le ratio. 6.2 Les deux sont multipliés par 10; le ratio ne change pas. 6.3 La formule combine des probabilités sans dimension, une gravité de 0 à 10, un dommage et une criticité de 0 à 1 et un facteur d'échelle; c'est un indicateur relatif servant au classement et à la comparaison.

Laboratoire 7. 7.1 Zéro, parce que l'atténuation multiplie les deux réductions. L'ensemble de mesures doit aussi réduire l'impact (par exemple, reprise testée, segmentation, détection). 7.2 Attribuez une part à chacun des sept scénarios (par exemple 180 000 $ ÷ 7 ≈ 25 714 $ chacun, plus une part du coût récurrent) pour l'analyse par scénario; comptez 180 000 $ une seule fois dans le total du portefeuille. 7.3 Son effet est déjà intégré à l'état actuel (il influe sur Pb(ψ,A) et θ); en tenir compte de nouveau compte deux fois la même réduction.

Laboratoire 8. 8.1 La question de savoir si S1 peut être accepté avec l'ensemble de mesures prévu (cas inférieur et central) ou s'il nécessite un traitement plus rigoureux, un transfert ou une acceptation formelle par le conseil d'administration (cas supérieur). 8.2 Non. Cela signifie que vos estimations sont cohérentes entre elles, et non qu'elles sont exactes. 8.3 θ divise à la fois Re et Rt; il s'annule donc dans le ratio.

Laboratoire 9. 9.1 Il n'a ni mesure, ni source, ni responsable, ni fréquence, ni seuil; personne ne peut savoir quand agir. 9.2 Parce qu'un dépassement survient lorsque la valeur s'élève au-dessus du seuil (par exemple, un taux de clics supérieur à 8 %). 9.3 Quatre relevés; un nombre inférieur de points ne permet pas d'établir une tendance, et une droite tracée à partir de trois points donnerait une fausse impression de précision.

Laboratoire 10. 10.1 Les membres de la haute direction lisent le premier paragraphe pour décider s'ils liront le reste; la note de service existe pour obtenir une décision. 10.2 Recalculez le classeur, déterminez quel chiffre est exact et corrigez chaque document pour qu'ils concordent; des chiffres incohérents minent l'ensemble de la recommandation. 10.3 Le membre de la haute direction responsable ou le conseil d'administration, selon la délégation de pouvoirs (dans le cas de MediBec, un risque résiduel supérieur à 0,40 normalisé exige l'acceptation du conseil d'administration).

Laboratoire 11. 11.1 Non. Une confiance de source est l'affirmation du producteur au sujet de l'indicateur, et non une probabilité que la menace agisse contre MediBec. 11.2 Une confirmation par une personne nommée à une date donnée (*Confirmer comme incident*). 11.3 Une règle ne peut pas détecter des événements qu'elle ne reçoit jamais; la couverture n'est validée que par un test de détection concluant avec une télémétrie fonctionnelle.

Laboratoire 12. 12.1 Cela vérifie l'existence, et non le fonctionnement. L'efficacité opérationnelle exige des éléments probants démontrant que les revues ont été effectuées sur une période, sur un échantillon, et que les exceptions ont été résolues. 12.2 Exemple : « Les propriétaires de systèmes doivent imposer l'authentification multifacteur pour tout accès à distance aux systèmes qui traitent des renseignements sur les patients, conformément à la norme d'authentification. » 12.3 Dans la norme d'authentification (ou norme sur les mots de passe), parce que les valeurs techniques changent plus vite que la politique et doivent pouvoir être mises à jour sans qu'il faille approuver de nouveau la politique.

Annexe E — Glossaire

Appétence pour le risque — le niveau de risque de cybersécurité que la direction est disposée à rechercher ou à conserver, sur une échelle de 0 à 1. **Chaîne causale** — la séquence source de la menace → faiblesse → actif → événement → conséquence qui définit un scénario de risque. **Joyaux de la couronne (actifs critiques)** — les actifs

et services dont la perte nuirait le plus à la mission. **Score de base CVSS v4.0 (CVSS-B)** — le score de gravité technique d'une vulnérabilité, de 0 à 10. **Risque estimé** — le risque d'un scénario de risque avant traitement, tel que calculé par la formule CRG. **ICR** — indicateur clé de risque : une valeur mesurée assortie de seuils qui signalent une variation du risque. **Risque atténué** — la part du risque estimé éliminée par le traitement. **Risque résiduel** — le risque qui demeure après le traitement. **Résilience organisationnelle (θ)** — la capacité démontrée de prévenir, détecter, contenir, intervenir, rétablir et maintenir les opérations critiques. **Risque toléré** — l'appétence appliquée à un scénario de risque précis au moyen de la formule CRG. **Contrôle partagé** — une initiative unique qui réduit plusieurs scénarios de risque; son coût est compté une seule fois dans le portefeuille.

© 2026 Marc-André Léger. Sous licence CC BY-NC 4.0. MediBec est une organisation fictive. Toutes les valeurs des paramètres sont des estimations analytiques fournies à titre illustratif à des fins pédagogiques.